DOCUMENTACION DE SISTEMA

RootCause Bitcoin Defense

09 · APIs e integraciones

Version analizada 0.3.0 · commit acdf4dd · generado el 2026-08-27
Documento 09 de la serie · fuente: docs/system-documentation/09-apis-and-integrations.md

Contenido

1 · Superficie de la API
2 · Cabeceras
3 · Endpoints de lectura
4 · Endpoints de escritura
5 · Formato de error
6 · Límites y control de tasa
7 · Integración con Bitcoin Core
8 · Otras integraciones
9 · Lo que la API deliberadamente no ofrece

El contrato HTTP que expone el sistema y las tres integraciones externas que puede usar, con su superficie exacta.

> `../API.md` documenta la API como referencia de uso. Aquí se añade lo que hace falta para **integrar o auditar**: cabeceras obligatorias, validación por campo, todos los códigos de error y los límites reales.

---

1 · Superficie de la API

Propiedad	Valor
Base	`http://127.0.0.1:8787` (configurable con `HOST` y `PORT`)
Protocolo	HTTP/1.1 sin TLS — **es loopback a propósito**
Formato	JSON en ambos sentidos, UTF-8
Autenticación	**Ninguna.** El control es el bind local
Versionado	No hay prefijo de versión; `GET /api/health` declara la versión del producto
CORS	**No se emiten cabeceras CORS.** Un origen distinto no puede leer las respuestas
Endpoints	15

---

2 · Cabeceras

2.1 · Que debe enviar el cliente

Cabecera	Cuándo	Consecuencia de omitirla
`content-type: application/json`	Toda petición con cuerpo	`415`
`x-rootcause-request: 1`	**Toda mutación** (POST, PUT, PATCH, DELETE)	`403 MUTATION_HEADER_REQUIRED`
`x-rootcause-actor: <etiqueta>`	Opcional	Se usa `local-user`
`accept: application/json`	Opcional	Ninguna

`x-rootcause-actor` se valida contra `/^[a-z0-9._@-]{1,80}$/i`. Un valor que no encaje **no da error**: se sustituye por `local-user`.

> `x-rootcause-request` es la protección CSRF: es una cabecera personalizada, y un formulario HTML de otro sitio no puede enviarla sin disparar una comprobación previa CORS que este servidor no responde.

2.2 · Que devuelve el servidor

Cabecera	Valor	En
`content-security-policy`	Política self-only completa	Todas
`cross-origin-opener-policy`	`same-origin`	Todas
`cross-origin-resource-policy`	`same-origin`	Todas
`x-content-type-options`	`nosniff`	Todas
`x-frame-options`	`DENY`	Todas
`referrer-policy`	`no-referrer`	Todas
`permissions-policy`	Cámara, micrófono, geolocalización, pago y USB deshabilitados	Todas
`x-request-id`	UUID v4 nuevo por petición	Todas
`cache-control`	`no-store`	Respuestas de API
`retry-after`	`60`	Solo en `429`

---

3 · Endpoints de lectura

3.1 · `GET /api/health`

Respuesta literal, sin tocar el servicio ni el estado:

```
{
 "status": "ok",
 "service": "rootcause-bitcoin-defense",
 "version": "0.3.0",
```

```
 "time": "2026-08-26T12:00:00.000Z"
}
```

> La versión está **escrita a mano** en `src/api/router.js`. `scripts/validate-repo.js` comprueba que coincida con `package.json` y falla si no: un endpoint de salud que miente sobre su versión es peor que no tenerlo.

Es el endpoint que usa el `HEALTHCHECK` del `Dockerfile` y la verificación de arranque del workflow de release.

3.2 · `GET /api/summary`

El endpoint principal del panel. Estructura de la respuesta:

`generatedAt`	
Tipo	ISO-8601
Contenido	Momento de la consulta

`mode`	
Tipo	`demo` \
Contenido	`persistent`
	Modo de persistencia

`risk.score`	
Tipo	0–100
Contenido	Puntuación agregada de los incidentes **activos**

`risk.level`	
Tipo	`critical` \
Contenido	`high` \
	`medium` \
	`low` \
	`clear`
	Umbrales 85 / 65 / 35 / > 0

`risk.counts`	
Tipo	objeto
Contenido	Conteo por severidad

`totals.wallets`, **`totals.signers`**, **`totals.activeIncidents`**, **`totals.watchedSats`**	
Tipo	enteros
Contenido	Métricas

`wallets`	
Tipo	array
Contenido	Inventario **completo**

`incidents`	
Tipo	array
Contenido	**Solo los 20 primeros**, ordenados por `lastSeenAt` descendente

`node`	
Tipo	objeto o `null`
Contenido	Último snapshot

`audit`	
Tipo	objeto
Contenido	Resultado de `verifyAuditChain`

> AVISO: **Límite de 20 incidentes.** No hay paginación ni parámetro para pedir más. Con más de 20 incidentes activos, el panel no muestra todos. `GET /api/incidents` sí devuelve la lista completa.

3.3 · Resto de endpoints de lectura

Endpoint	Devuelve	Notas
`GET /api/wallets`	`{ wallets: [...] }`	Inventario completo, sin filtros
`GET /api/incidents`	`{ incidents: [...] }`	**Todos**, sin límite
`GET /api/advisories`	`{ advisories: [...] }`	El contenido de `config/advisories.json` tal cual
`GET /api/policies`	El documento de política	El contenido de `config/policies.json` tal cual
`GET /api/posture`	`{ generatedAt, deployment, risk, findings }`	**Calculado en el momento**, no persistido
`GET /api/audit`	`{ verification, entries }`	Últimas **200** entradas, en orden inverso

`GET /api/posture` incluye un bloque `deployment` con `mode`, `host`, `port`, `watchtowerEnabled`, `remoteRpcAllowed` y `rpcAuth` — este último con valor `"cookie"`, `"password"` o `"sin credenciales"`. **No expone la contraseña, ni la ruta de la cookie, ni la clave de datos.**

---

4 · Endpoints de escritura

Todos exigen `x-rootcause-request: 1` y `content-type: application/json`.

4.1 · `POST /api/wallets` → `201`

Campo	Tipo	Obligatorio	Validación
`name`	cadena	**Sí**	1–120 caracteres tras `trim`
`fingerprint`	cadena	**Sí**	Exactamente 8 hex
`walletType`	enum	**Sí**	`single-sig` | `multisig`

Campo	Tipo	Obligatorio	Validación
`network`	enum	No	Defecto `mainnet`
`balanceSats`	entero	No	≥ 0, defecto `0`
`status`	enum	No	Defecto `active`
`quorum.required`	entero	No	1–5; defecto 1 en single-sig, 2 en multisig
`quorum.total`	entero	No	1–5; defecto = número de firmantes
`signers`	array	**Sí**	1–5 elementos
`signers[].fingerprint`	cadena	**Sí**	Exactamente 8 hex
`signers[].vendor`	cadena	**Sí**	1–80 caracteres
`signers[].model`	cadena	**Sí**	1–80 caracteres
`signers[].firmwareAtSeedCreation`	cadena	No	Defecto `"unknown"` → dispara `BTC-KEY-002`
`signers[].firmwareTrack`	cadena	No	Defecto `"standard"`
`signers[].seedOrigin`	enum	No	Defecto `"unknown"` → dispara `BTC-KEY-003`
`signers[].label`	cadena	No	Defecto `"Firmante N"`
`tags`	array	No	Máx. 10, cada una ≤ 30 caracteres

Errores: `422` material secreto · `400` validación · `409` huella duplicada.

Ejemplo seguro, con datos ficticios:

```
curl -s -X POST http://127.0.0.1:8787/api/wallets \
 -H "content-type: application/json" \
 -H "x-rootcause-request: 1" \
 --data @examples/wallets.sample.json
```

4.2 · `POST /api/scan` → `200`

Sin cuerpo relevante; se envía `{}`. Devuelve:

```
{
 "scannedAt": "2026-08-26T12:00:00.000Z",
 "findings": 3,
 "counts": { "critical": 2, "high": 0, "medium": 1, "low": 0, "info": 0 },
 "incidents": []
}
```

`incidents` trae la lista **completa** tras refundir.

4.3 · `PATCH /api/incidents/{id}` → `200`

`{id}` debe casar con `/^[a-f0-9]{20}$/`; cualquier otra forma da `404` sin llegar al servicio.

Campo	Valores	Efecto
`status`	`acknowledged`	Fija `acknowledgedAt` y `acknowledgedBy`; **el hallazgo sigue activo**
`status`	`resolved`	Fija `resolvedAt` y `resolvedBy`; **volverá a abrirse si la condición persiste**

Cualquier otro valor da `400`.

4.4 · `POST /api/approvals` → `201`

Campo	Obligatorio	Validación
`hash`	**Sí**	Exactamente 64 hex
`label`	No	≤ 120 caracteres, defecto `"PSBT aprobada"`
`expiresAt`	No	Fecha parseable. [ATENCION] **Se guarda pero ninguna regla lo comprueba**

4.5 · `POST /api/observe/transaction` → `201`

Campo	Obligatorio	Validación
`txid`	**Sí**	Exactamente 64 hex
`walletId`	**Sí**	≤ 80 caracteres. [ATENCION] No se comprueba contra el inventario
`spendsWatchedWallet`	No	Booleano, **defecto `true`**
`valueSats`	No	Entero ≥ 0. Sin él, `BTC-TX-002` no puede evaluarse
`approvalHash`	No	64 hex; se cruza con `approvals`
`source`	No	≤ 30 caracteres, defecto `"manual"`

`observedAt` lo pone **siempre el servidor**: no se acepta del cliente.

4.6 · `POST /api/observe/privacy` → `201`

Campo	Obligatorio	Validación
`type`	**Sí**	**Solo** `bulk_customer_data_access`; cualquier otro da `400`
`vendor`	**Sí**	≤ 120 caracteres
`recordCount`	**Sí**	Entero ≥ 1
`authorized`	No	Solo `true` explícito; cambia critical → medium

4.7 · `POST /api/node/refresh` → `200`

Sin cuerpo. Ejecuta cuatro llamadas RPC y guarda el snapshot.

Situación	Respuesta
Cliente RPC no configurado	`503`
Nodo inalcanzable	`200` con `node.connected: false` y `node.error`
Nodo disponible	`200` con el snapshot completo

> Que un nodo caído devuelva `200` es deliberado: **la consulta se hizo y su resultado es «no responde»**, que es exactamente el dato que alimenta `BTC-NODE-001`.

---

5 · Formato de error

Uniforme en toda la API:

```
{
 "error": {
   "code": "SECRET_MATERIAL_REJECTED",
   "message": "Forbidden secret field rejected at request.signers[0].mnemonic"
 }
}
```

Código HTTP	code	Mensaje
400	`REQUEST_REJECTED`	Detalle real del error
403	`MUTATION_HEADER_REQUIRED`	`Missing local mutation header.`
403	`CROSS_SITE_REQUEST_REJECTED`	`Cross-site mutation rejected.`
404	`NOT_FOUND`	`API route not found.` o `Resource not found.`
405	`METHOD_NOT_ALLOWED`	`Method not allowed.`
409	`REQUEST_REJECTED`	Detalle real
413	`REQUEST_REJECTED`	`Request body exceeds the configured limit.`
415	`REQUEST_REJECTED`	`Content-Type application/json is required.`
422	`SECRET_MATERIAL_REJECTED`	Detalle con la ruta del campo
429	`RATE_LIMITED`	`Too many requests.`
500	`INTERNAL_ERROR`	**`The request could not be completed.`** — genérico a propósito
503	`REQUEST_REJECTED`	`Bitcoin Core connector is not configured.`

> El mensaje del `422` incluye la ruta del campo ofensivo (`request.signers[0].seed`) **pero nunca su valor**. Ayuda a corregir sin reproducir lo que se rechazó.

---

6 · Límites y control de tasa

Límite	Valor por defecto	Configurable con
Peticiones por minuto y origen	120	`RATE_LIMIT_PER_MINUTE` (10–10000)
Tamaño de cuerpo	64 KiB	`REQUEST_BODY_LIMIT_BYTES` (1 KiB–1 MiB)
Timeout de petición	15 s	`server.requestTimeout`
Timeout de cabeceras	10 s	`server.headersTimeout`
Keep-alive	5 s	`server.keepAliveTimeout`
Firmantes por wallet	5	Constante
Etiquetas por wallet	10	Constante
Incidentes en `summary`	20	Constante
Entradas de auditoría en `audit`	200	Constante

Aspecto	Situación
Reintentos	**No hay.** Ni en la API ni en el cliente RPC
Retroceso exponencial	No aplica
Idempotencia	`POST /api/scan` es idempotente. `POST /api/wallets` es idempotente por efecto: un `409` en el segundo intento
Paginación	**No existe** en ningún endpoint

---

7 · Integración con Bitcoin Core

Propiedad	Valor
Protocolo	JSON-RPC 2.0 sobre HTTP POST
Autenticación	Basic con cookie del nodo (recomendado) o usuario y contraseña
Destino	Loopback obligatorio salvo `ALLOW_REMOTE_RPC=true`
Timeout	`BITCOIN_RPC_TIMEOUT_MS`, 5 s por defecto
Redirecciones	**Rechazadas** (`redirect: "error"`)
Tamaño máximo de respuesta	2 MiB, comprobado por cabecera y por cuerpo
Métodos permitidos	11, todos de lectura
Métodos usados por `snapshot()`	`getblockchaininfo`, `getnetworkinfo`, `getmempoolinfo`, `getpeerinfo`

Cuerpo de una llamada:

```
{ "jsonrpc": "2.0", "id": 1, "method": "getblockchaininfo", "params": [] }
```

Manejo de errores:

Situación	Comportamiento
Método fuera de la allowlist	Lanza antes de tocar la red
Cookie sin `:`	Lanza `Invalid Bitcoin Core cookie file.`
HTTP no OK	Lanza con el código
Error JSON-RPC en el cuerpo	Lanza con código y mensaje del nodo
Timeout	`AbortError`
Cualquiera de los anteriores dentro de `snapshot()`	Se captura y devuelve `{connected: false, error}`

Por qué la cookie es preferible: el nodo la rota solo, no hay que escribirla en ningún archivo de configuración y no acaba en el entorno del proceso ni en un historial de shell. Usar usuario y contraseña dispara `BTC-OPSEC-005`.

Por qué `redirect: "error"`: sin esa opción, un nodo comprometido podría redirigir la petición —**con la cabecera `authorization` incluida**— a un destino controlado por el atacante.

---

8 · Otras integraciones

8.1 · Node.js Security WG

Propiedad	Valor
Cuándo	**Solo** al ejecutar `scripts/check-runtime-advisories.js`
Método	`GET` al índice de vulnerabilidades del Security WG
Timeout	20 s
Sin red	Falla con código ≠ 0, o **declara cobertura 0 %** con `--offline-ok`

> La regla es explícita en el propio script: *sin datos no hay auditoría; esto no es un verde, es una comprobación que no pudo hacerse*.

8.2 · Distribución oficial de Node.js

Propiedad	Valor
Cuándo	**Solo** al empaquetar para Windows
Qué descarga	El ZIP del runtime y `SHASUMS256.txt`
Verificación	**SHA-256 comparado contra el archivo oficial.** Si no coincide, el empaquetado aborta

8.3 · GitHub Actions

Integración	Uso
`actions/checkout`, `setup-node`, `upload-artifact`, `upload-pages-artifact`, `configure-pages`, `deploy-pages`	CI, releases y Pages
`github/codeql-action`	Análisis estático
`gh` CLI	Creación del release — **sin action de terceros**
`gitleaks`	Descargado del release oficial y **verificado por checksum**
`zizmor`, `hadolint`	Análisis de workflows y del Dockerfile

Todas las actions están pinneadas a **commit SHA**, no a etiqueta. Dependabot las actualiza semanalmente, agrupando `github/codeql-action*` porque `init` y `analyze` deben subir juntas.

---

9 · Lo que la API deliberadamente no ofrece

Ausencia	Por qué
`DELETE` de cualquier recurso	El historial es evidencia
Edición de wallets	Cambiar la procedencia declarada invalidaría el análisis previo sin traza
Endpoint de firma o transmisión	**Es el principio no negociable del producto**
Endpoint de exportación de estado	Reduce la superficie de fuga
Webhooks o notificaciones salientes	Serían un canal de salida de datos
Autenticación y usuarios	El modelo es de un solo operador local
CORS	Ningún origen externo debe leer estas respuestas
Paginación	Los volúmenes previstos no la requieren

Siguiente	
Todas las variables de configuración	`10-configuration.md`
Análisis de seguridad	`11-security.md`
Volver al índice	`README.md`